

Written Information Security Plan

Keeping personnel informed, accountable, and ready to protect client information.

Why every firm needs WISP training

Tax, accounting, and advisory firms routinely handle high-value personal and financial data. A WISP is not just a policy requirement; it is the operating standard for how we prevent misuse, detect issues early, and respond fast when something goes wrong.

- FTC Safeguards Rule and IRS expectations require firms handling sensitive client information to maintain documented security practices.
- Training is how policies become repeatable behavior across owners, employees, contractors, and temporary staff.
- Security failures often begin with normal workflows: email, shared files, browsers, printing, remote access, or misplaced paper records.
- A strong WISP reduces regulatory exposure, operational downtime, reputational damage, and client harm.

CORE CONCEPT

What counts as personally identifiable information (PII)

PII is any information that can identify a client, employee, taxpayer, or related person directly or when combined with other data. Treat anything sensitive enough to enable fraud, impersonation, account access, or disclosure risk as protected information.

- Names, home addresses, phone numbers, email addresses, and dates of birth
- Social Security numbers, taxpayer IDs, driver's license or state ID numbers
- Bank details, payroll data, card data, retirement information, login credentials, and security answers
- Tax returns, source documents, bookkeeping exports, engagement files, and notes containing client identifiers

How sensitive information is commonly exposed

Common attack paths

- Phishing emails and fake login pages
- Unsecured remote access or weak passwords
- Improper file sharing and email attachments
- Lost laptops, phones, USB drives, or printed documents
- Unauthorized insider access or careless handling

Common workflow mistakes

- Leaving files open on desks or printers
- Using personal storage or personal email for firm data
- Clicking unknown links before verifying the sender
- Saving documents in the wrong folder or portal
- Failing to report suspicious activity immediately

Physical safeguards

Physical safeguards protect paper records and devices in the real world. They matter just as much as passwords or firewalls because an exposed return folder or unlocked laptop can create the same breach impact as a hacked account.

- Clear desks, conference rooms, printers, and shared work areas at the end of each task and each day.
- Store paper files, backup media, and devices containing PII in approved locked locations only.
- Use privacy screens, locked offices, and screen locks whenever you step away from your workstation.
- Do not leave firm records or devices unattended in vehicles, home common areas, or public spaces.

Technical safeguards

Technical safeguards protect systems, files, networks, and communications. Employees are expected to follow the firm's approved access, device, and transmission standards every time they handle sensitive information.

- Use approved firm accounts, unique passwords, and multi-factor authentication where required.
- Keep operating systems, browsers, tax software, and endpoint protection current.
- Use only approved storage, portals, cloud apps, and collaboration tools for firm data.
- Never bypass encryption, secure transfer methods, or device-management controls to save time.

Administrative safeguards and role accountability

What leadership owns

- Maintain current written policies and procedures
- Assign responsible roles and review compliance
- Approve vendors and control third-party access
- Provide training and retain acknowledgement records

What every employee owns

- Follow firm procedures exactly as written
- Use only the minimum information needed for the task
- Report suspicious events, access issues, and mistakes immediately
- Protect confidentiality even after a task is complete

What to do when something looks wrong

Speed matters. Do not wait to be sure that an event is a real breach before escalating it. Early reporting gives the firm a chance to contain access, preserve evidence, notify the right people, and protect affected clients quickly.

- ☐ Stop the activity if it is safe to do so and disconnect the affected device or session if instructed.
- ☐ Report the issue immediately to the Data Security Coordinator or designated incident contact.
- ☐ Do not delete evidence, alter files, or continue using a suspected compromised account.
- ☐ Document what happened, when it happened, what data may be involved, and who has already been informed.
- ☐ Use only approved communications channels for follow-up; do not discuss incidents casually or externally.

Non-negotiable employee practices

These habits should feel routine. If a shortcut would weaken control over client information, it is not an acceptable shortcut.

- ☐ Verify unexpected payment, bank-change, portal, or document-release requests before acting.
- ☐ Limit access to PII to what is necessary for your assigned work only.
- ☐ Use secure browsers, trusted networks, and approved remote-access methods.
- ☐ Keep personal apps, personal storage, and personal accounts separate from firm business.
- ☐ Escalate anything unusual: misdirected emails, strange logins, missing files, unusual client requests, or device loss.

How to think in real situations

Security is easiest to follow when personnel know how to react under pressure. The goal is not perfection; the goal is disciplined escalation, controlled handling, and fast reporting.

- A client emails tax documents to the wrong address: do not forward casually; report, contain, and confirm deletion steps.
- A link in an email asks you to re-authenticate quickly: pause, verify the sender independently, and do not log in through untrusted prompts.
- You notice files left on a shared printer: secure them immediately and notify the owner or supervisor.
- A laptop or phone used for firm work is lost: report it at once so access, device controls, and account protections can be triggered.

COMPLETION

What happens next

Training should end with action. Every employee, contractor, or temporary team member with access to protected information should know what they received, what they are expected to do, and where to go when they are unsure.

- Review the firm's current WISP and related procedures after this session.
- Acknowledge that you received the training and understand your responsibilities.
- Ask questions now if any workflow, device, or communication practice is unclear.
- Revisit this training annually and whenever firm procedures change materially.